信息安全测评与风险评估

7.1.1 云平台架构认知

授课教师：张玉



目录

CONTENTS

01 案例导入——“一朵云引发的安全思考”

02 学习目标

03 什么是云计算？

04 云计算的发展历程

案例导入——“一朵云引发的安全思考”（10分钟）



云计算70年发展史：从算力共享到AI时代智算底座_哔哩哔哩_bilibili

案例素材

2021年，某互联网公司因云平台配置不当，导致存储权限设置为“公开”，**超100万用户数据被泄露**。事后调查发现：该公司将核心业务系统部署在公有云上，但未正确理解**云安全责任共担模型**，误以为云服务商会负责所有安全。

问题讨论

- 这家公司把数据放在云上，数据泄露谁的责任？
- “云安全”等于“云服务商的安全”吗？

结论：云计算带来灵活性的同时，也带来了责任边界的问题。理解云平台架构，是开展云计算安全测评的第一步。

学习目标

通过本课学习，你将能够：

01 理解	云计算的基本概念、特征和服务模式
02 掌握	三种云服务模式（IaaS、PaaS、SaaS）的核心区别
03 理解	云安全责任共担模型及其在等保测评中的应用
04 能够	识别云计算安全扩展要求在等保中的定位

什么是云计算？

NIST 定义

云计算是一种无处不在、便捷且按需地对一个共享的可配置计算资源池进行网络访问的模式，能够通过最少的管理工作实现资源的迅速供给和释放。

通俗理解：云计算就是把计算能力（服务器、存储、网络、软件）像水、电一样，按需取用、按量付费。

云计算的五大基本特征：

按需自助服务

用户无需人工交互，即可自行配置和使用计算资源

广泛的网络接入

可通过各种终端设备（手机、电脑）通过网络访问

资源池化

计算资源被汇集起来，动态分配给多个用户

快速弹性伸缩

资源可根据需求快速扩展或收缩

可计量服务

使用量可监控、计量，按使用量付费

云计算的发展历程

1960年代

约翰·麦卡锡提出“计算公用事业”理念

（云计算思想的起源）

2006年

谷歌CEO施密特首次提出“云计算”概念

（术语诞生）

2006年

亚马逊推出EC2计算云服务

（云计算正式进入商用）

2000s-2010s

虚拟化技术成熟（VMware、KVM、Xen）

（虚拟化时代）

云计算的三种服务模式（核心知识点）

三种模式：IaaS、PaaS、SaaS——记住一句话： IaaS给“地基”，PaaS给“毛坯房”，SaaS给“精装房”。



IaaS（基础设施即服务）

提供商提供：计算、存储、网络资源
用户管理：操作系统、中间件、应用、数据
典型产品：AWS EC2、阿里云ECS、OpenStack

比喻：“租地自己盖楼”



PaaS（平台即服务）

提供商提供：操作系统、开发环境、数据库
用户管理：应用、数据
典型产品：Google App Engine、阿里云PaaS

比喻：“租房拎包入住”



SaaS（软件即服务）

提供商提供：完整的应用程序
用户管理：用户数据
典型产品：钉钉、腾讯会议、企业邮箱

比喻：“住酒店”

三种服务模式——控制权与责任对比图

素材2：三种云服务模式对比卡（学生



高控制权 **IaaS**

用户管理：OS、中间件、应用、数据

云服务商管理：虚拟化、硬件、网络

中控制权 **PaaS**

用户管理：应用、数据

云服务商管理：OS、中间件、运行时

低控制权 **SaaS**

用户管理：数据

云服务商管理：全部

控制权从高到低：IaaS > PaaS > SaaS（用户拥有越多控制权，安全责任越大）

云安全责任共担模型——客户与云服务商各管一摊

素材4：云安全责任共担模型示意图.(

云安全责任共担模型 是云计算安全测评的“第一原则”。

责任划分矩阵

责任项	IaaS	PaaS	SaaS	核心说明
数据安全	客户	客户	客户	客户的数据归客户负责
访问控制	客户	客户	客户	谁来访问、怎么访问，客户自己管
操作系统	客户	云服务商	云服务商	IaaS下客户需自己管理OS安全
虚拟化层	云服务商	云服务商	云服务商	多租户隔离由云服务商保证
硬件/网络	云服务商	云服务商	云服务商	物理安全是云服务商的责任

无论哪种模式，数据安全永远是客户的责任 ——云服务商不会替客户保护数据。

云计算的部署模式

公有云

第三方提供商拥有，公众可通过互联网使用。

适用场景：中小企业、开发测试。

安全风险：数据出境风险、多租户隔离风险。

私有云

为单一组织专有使用，可自建或托管。

适用场景：政府、金融、大型企业。

安全风险：成本高，但安全可控。

社区云

由多个有共同关切的组织共享。

适用场景：行业内部（如医疗、教育）。

安全风险：共享安全边界。

混合云

两种以上部署模式的组合。

适用场景：核心数据本地+弹性业务云端。

安全风险：边界管控复杂。

云计算给等保测评带来了哪些新挑战？

GB/T 22239-2019 扩展要求——云计算安全扩展要求



边界模糊

物理边界消失，传统基于物理边界的安全措施失效



责任边界

等保要求中哪些是云服务商的责任，哪些是客户的责任？



数据位置

数据存储在哪里？是否跨境？是否符合“基础设施位于中国境内”？



虚拟化安全

虚拟机之间的攻击、逃逸等新型威胁



多租户隔离

不同客户的数据/流量如何隔离？

云计算安全扩展要求——在等保标准中的位置

GB/T 22239-2019 安全扩展要求 → 云计算安全扩展要求

云计算安全扩展要求的十个维度：

1. **安全物理环境**：基础设施位置（境内）
2. **安全通信网络**：网络架构（等级匹配）
3. **安全区域边界**：访问控制、入侵防范等
4. **安全计算环境**：身份鉴别、数据保护等
5. **安全管理中心**：集中管控
6. **安全管理制度**：责任约定
7. **安全管理机构**：权限划分
8. **安全管理人员**：人员资质
9. **安全建设管理**：服务商与供应链
10. **安全运维管理**：云环境管理

重点解读——第一级/第二级 vs 第三级/第四级

不同级别的安全要求差异：

第一级/第二级		第三级/第四级
基础设施位于中国境内	安全物理环境	基础设施位于中国境内（同左）
平台不承载高于自身等级的业务	安全通信网络	**新增：**客户可自主设置安全策略、开放接口接入第三方安全产品
虚拟化网络边界部署访问控制	安全区域边界	**新增：**虚拟网络节点攻击检测、异常流量检测、告警
访问控制策略随虚拟机迁移	安全计算环境	**新增：**双向身份验证、资源隔离失效检测、恶意代码检测

上机准备——CloudLab 云计算实验平台

🌐打开方式：双击 cloudlab-experiment.html（本地页面，无需账号，浏览器直接打开）——这就是本课程配套的 CloudLab 云计算实验平台（模拟环境）。

📖六个页面，与本节课知识点一一对应：

① 平台概览与架构——四层架构图（物理层→虚拟化层→管理平台层→服务层）、资源池、租户信息
② 云主机管理——虚拟机规格与镜像（观察：有没有虚拟机用的是未加固的默认镜像？）
③ 网络与安全组——VPC 隔离与安全组规则（警惕 0.0.0.0/0 全放行规则）
④ 存储与备份——云硬盘备份策略、对象存储桶访问权限
⑤ 审计与告警——特权操作日志、入侵检测告警
⑥ 等保核查任务——测评记录表填写与配置风险分析（下节课 7.1.2 的主战场）

🕐现在花 3 分钟自由浏览，带着一个问题看：这朵“云”里，哪些部件是云服务商管的？哪些是租户自己管的？（下节课我们就在这个平台上做安全配置核查）

教师演示——云平台架构图解析（15分钟）



物理层：服务器集群、存储阵列、网络设备

虚拟化层：KVM、Ceph、Neutron

管理平台层：资源池、虚拟机、网络、存储

服务层：IaaS基础服务（虚拟机、云盘、VPC）

教师演示步骤

素材5：教师演示用——云平台架构

1. 打开 CloudLab「平台概览」页，查看资源池
2. 切到「云主机管理」页，理解“租户”概念
3. 切到「网络与安全组」页，理解VPC隔离
4. 切到「存储与备份」页，看云硬盘/对象存储

重点强调

这些资源是如何被“隔离”的？

不同租户之间能看到对方吗？

实践任务1——云平台架构认知（20分钟）

任务名称

云平台架构认知与资源查看

素材1：实践任务
——《云平台架构认

任务场景

打开 CloudLab 实验平台（模拟环境），依次浏览左

任务内容

① 查看资源池划分（计算、存储、网络）

② 查看虚拟机列表及规格

③ 查看虚拟网络配置（VPC/子网）

④ 查看安全组策略

⑤ 查看租户信息与资源配额

时间安排

约 20 分钟

CloudLab 页面对照：①⑤→「平台概览」②→「云主机管理」③④→「网络与安全组」

实践任务1——《云平台架构认知记录表》

观察项	记录内容	安全相关说明
资源池划分	（记录CPU/内存/存储总量及分配）	资源隔离是等保要求的基础
虚拟机规格	（记录云主机的vCPU/内存/磁盘配置）	不同级别系统需要不同规格保障
虚拟网络（VPC）	（记录VPC名称、网段、子网划分）	网络隔离是等保8.2.2.1b)的要求
安全组/防火墙规则	（记录已配置的安全组策略）	访问控制是等保8.2.3.1的要求
租户/项目	（记录租户名称及资源配额）	多租户隔离是云安全的基石

上机填写：登录 CloudLab 实验平台（cloudlab-experiment.html），在各页面顶部“观察点”提示下逐项取证，完成本记录表。

思考题：你认为云平台最核心的安全机制是什么？

实践任务2——服务模式辨识（15分钟）



素材3：云服务模式辨识练习.docx

任务背景

任务名称：辨识三种云服务模式

任务场景：教师提供10个常见的云服务/产品名称，学生判断属于IaaS/PaaS/SaaS哪一种

任务内容

01 逐个判断服务模式

02 说明判断理由（关键特征）

03 讨论：每种模式的安全责任边界有什么不同？

示例清单

① 阿里云ECS（云服务器）	IaaS
② 钉钉	SaaS
③ 华为云RDS（云数据库）	PaaS
④ 腾讯云对象存储COS	IaaS
⑤ 企业邮箱	SaaS
⑥ 百度云BCC（云服务器）	IaaS
⑦ Google App Engine	PaaS
⑧ Salesforce	SaaS
⑨ OpenStack	IaaS
⑩ 阿里云PolarDB	PaaS

责任共担模型——测评视角下的应用

在等保测评中，首先要明确：哪些要求是云服务商的？哪些是云服务客户的？

测评对象	责任方	核心内容
物理机房	云服务商	基础设施位于中国境内
虚拟化平台	云服务商	虚拟机之间隔离、资源隔离失效检测
虚拟网络	双方协作	VPC隔离、访问控制策略
客户虚拟机	云服务客户	操作系统安全配置、身份鉴别
客户数据	云服务客户	数据保密性、完整性、备份
客户应用	云服务客户	应用安全功能验证

思政融入——云安全关乎国家安全

主权

等保2.0要求“云计算基础设施位于中国境内”

数据不出境，是国家网络空间主权的体现

责任

数据安全永远是客户的责任

不能因为“上云”就把安全责任推给服务商

合规

《网络安全法》明确规定国家实行网络安全等级保护制度

云上系统同样需要等保测评

云上安全，责任共担——边界可以模糊，责任不能模糊。

知识点回顾（5分钟）

云平台架构认知

1. **云计算基本概念**（定义NIST、五大特征）
2. **三种服务模式**（IaaS、PaaS、SaaS）
3. **部署模式**（公/私/社区/混合云、等保位置）
4. **安全责任共担**（云商负责硬件，客户负责数据）
5. **云安全扩展要求**（等保2.0位置、十个安全维度）

课后作业

必做	完成《云平台架构认知记录表》（登录 CloudLab 实验平台对照填写），提交至
必做	完成活动7.1.1在线测试（选择题+判断题，共15题）
选做	绘制一张云安全责任共担模型示意图
预习	预习7.1.2“云安全配置核查”相关内容

下节课预告

7.1.2 云安全配置核查

预告内容

- 云计算安全扩展要求测评指标
- 云平台安全配置核查方法
- 《云计算安全测评记录表》填写

课前准备

1. 复习GB/T 22239云计算扩展要求
2. 了解云平台安全组/防火墙配置

课堂小结与答疑

3
核心知识点

① 云计算的三种服务模式（IaaS/PaaS/SaaS）

② 安全责任共担模型——数据安全永远是客户的责任

③ 云计算安全扩展要求是等保2.0的重要组成部分

2
关键技能

① 能辨识云服务模式

② 能理解云平台架构

1
职业准则

云上系统同样需要等保测评

感谢观看

